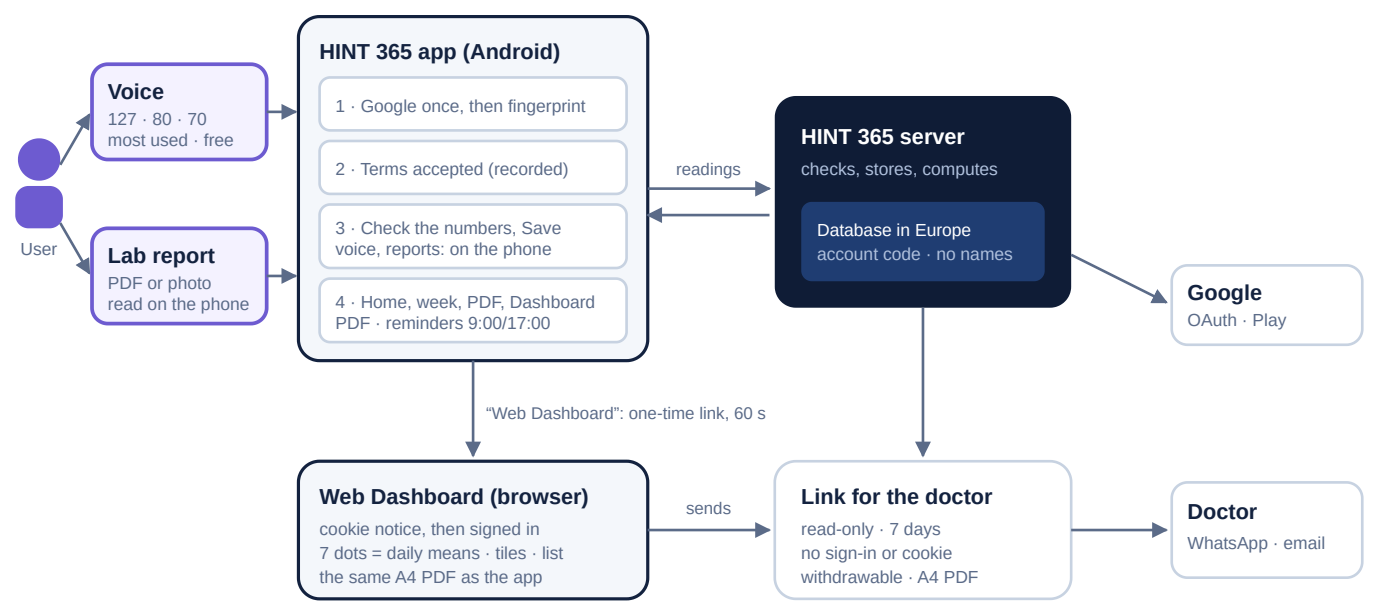


Functional overview

What the app does, who does what and in which order. A blood-pressure diary for Android, with a web dashboard and reports for the doctor.

The flow from the phone to the doctor



The user's path

1. **Installs** the app from the public link `/download` (later from Google Play).
2. **Signs in with Google** once, through OAuth 2.0 / OpenID Connect (a signed ID token, never the password), and gives privacy consent.
3. **Accepts the terms of use**, binding, at the first installation and after every update: without acceptance the app does not open. Every acceptance is recorded (pseudonymous account code, phone, versions, text fingerprint, date).
4. **Every day** unlocks with the phone's fingerprint or PIN, and stays signed in until "Sign out".
5. **Imports lab reports** by itself: PDF or photo read on the phone, every test (also outside the catalog), one report date; any doubt: nothing saved; never twice.
6. **Records** a reading: by voice or with a photo of the monitor (Scan, an AI feature marked by a small wand: 15-day trial then 4 \$ a year, 3 a day via the Worker and Anthropic, up to 30 with the person's own key; **SYS**, **DIA**, **PUL** checked and confirmed on screen). The photo is never stored (terms v21).
7. **Looks back**: last reading, the week; "Go to your full reports" at the end of Blood pressure or Lab results opens that page of the Web Dashboard in the browser (Blood pressure first: chart, eight tiles, morning/evening balance, pulse; then Lab results).
8. **Shares**: the PDF downloaded on the phone, or Web Dashboard → "Send to the doctor".
9. **Changes phone**: signs in with Google and finds everything. **Signs out or deletes the account** at any time.

Costs and who is paid

What	Cost	Paid to
HINT 365: app, voice, lab results, charts, reports, Web Dashboard, keeping the readings	Free	Nobody
AI features: the Scan, up to 3 a day	15 days free, then 4 \$ a year	The app's owner, through Google Play

The app is free; only the AI features are paid, at most 3 \$ of AI per person a year. With one's own AI key: up to 30 Scans a day, paid to that provider.

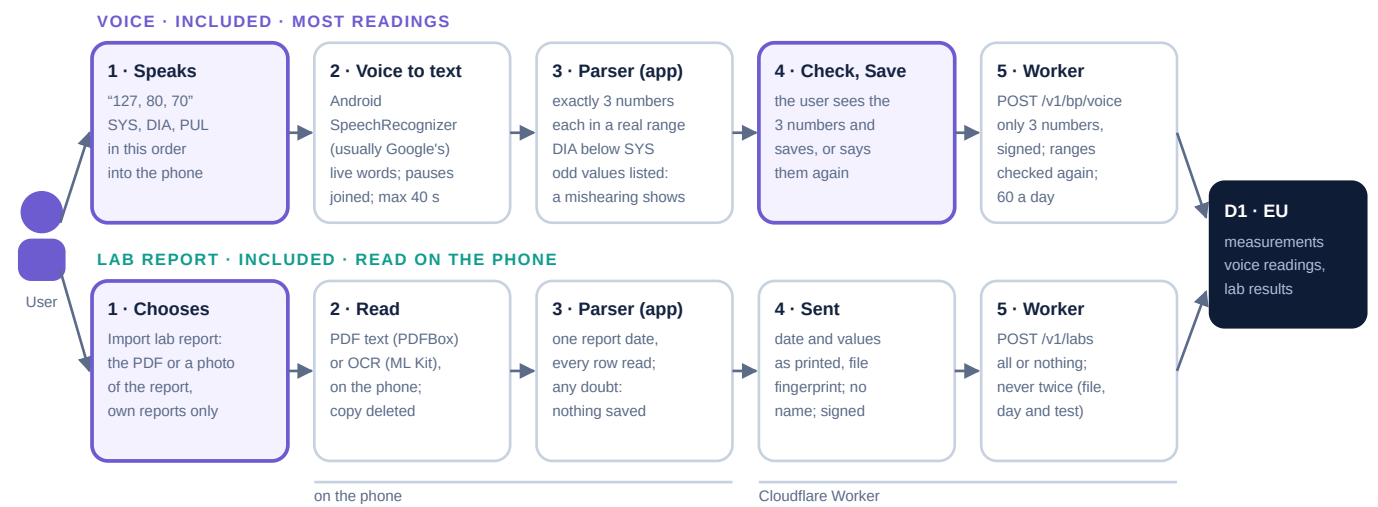
Fixed rules

- No diagnosis, no advice, no judgement of the values: no coloured zones, no "normal".
- Labels always **SYS**, **DIA**, **PUL**. Pressure and pulse never in the same chart.
- Charts: 7 days, one dot per day = the mean of that day's readings (explained before the charts), value next to it, axis with day numbers only. Tables show AM/PM.
- The same A4 PDF from the app and from the web.
- No red anywhere: **SYS** violet, **DIA** teal, **PUL** amber. No colour means "good" or "bad".
- Scan (terms v21): an AI feature, free for 15 days from the first Scan (once per Google account and per phone, HMAC fingerprints in `scan_trials`), then with the 4 \$ yearly subscription (at most 3 \$ of AI per person a year, counted from Anthropic's token usage); 3 a day per person through the Worker to Anthropic (Claude Haiku 4.5) with the owner's key (secret `AI_API_KEY`; photo passed on, never stored or logged); up to 30 a day with the person's own key (Claude, ChatGPT, Gemini or Kimi), kept encrypted on the phone, photo phone → provider. Only the three confirmed numbers are stored.
- Readings kept at most 365 days, deleted nightly; acceptances stay as proof.
- The app stays simple: the owner's controls are only in the web Admin area.

Input: voice and lab reports

How data enters HINT 365: blood pressure by voice or by a photo of the monitor (Scan), lab results from a report. Voice and lab reports are read on the phone; the Scan is read with AI (terms v21): through the Worker to Anthropic, or with the person's own key straight to their provider.

From the user to the database the input always starts on the user's side



Purple frame: a step done by the user. Voice: the numbers are recognised on the phone and only the three numbers travel. Lab report: the document stays on the phone; only the date and the values as printed travel.

The differences

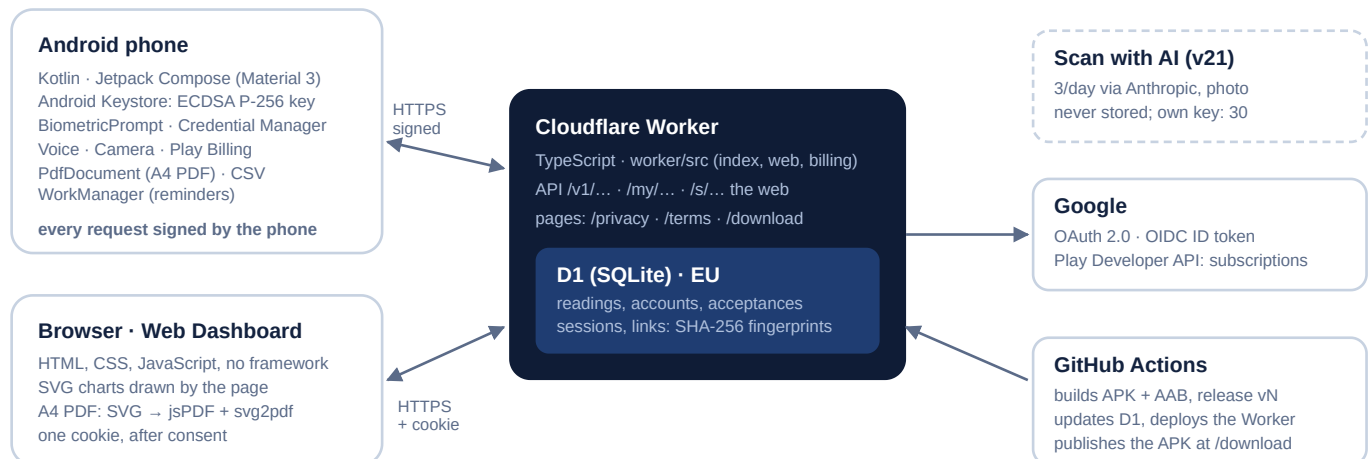
	Voice (blood pressure)	Lab report
Who can use it	everyone, included in the app	everyone, included in the app; own reports only (terms v18)
What the user does	says the three numbers	picks the laboratory's PDF or a photo of the report
Where it is recognised	on the phone: Android speech recognition (usually Google's service), then HINT 365's own parser (<code>parseSpoken</code>)	on the phone: PDF text (PDFBox) or on-device OCR (ML Kit), then <code>LabsParser.kt</code>
What leaves the phone	only the three numbers (the sound goes only to the phone's speech service)	the report date and the results as printed, and a keyed file fingerprint; never the document or a name
Cost	none	none
Checks	exactly 3 numbers; SYS 50–260, DIA 30–160, PUL 30–220; DIA below SYS; odd values listed; user confirms; ranges again on the server	one report date and every row understood, or nothing saved; server: schema, same file or same test and day never twice
Typical errors	a misheard number, noise, numbers said in the wrong order	an unclear photo, two dates on the document, an encrypted PDF
Limits	60 a day	PDF up to 15 pages, 20 MB
Stored as	<code>measurements</code> , <code>source voice</code> or <code>photo (Scan)</code>	<code>measurements</code> , <code>kind lab</code> ; <code>lab_files</code> fingerprint
Code	<code>Listen.kt</code> , <code>Core.kt</code> (<code>parseSpoken</code>), <code>POST /v1/bp/voice</code>	<code>Labs.kt</code> , <code>LabsParser.kt</code> , <code>POST /v1/labs</code>

Scan (photo of the monitor): camera → by default `POST /v1/bp/photo/read` (trial or subscription, else `402 scan_locked`; 3 a day and 3 \$ a year per person; Claude Haiku 4.5 with the owner's key; photo not stored) → Claude answers JSON only; or, with the person's own key (checked with the provider's model list, AES-GCM-encrypted with the Android Keystore), phone → provider directly, up to 30 a day → plausibility check → the photo and the numbers on screen → the person confirms → `POST /v1/bp/photo` (3 numbers only); the photo is deleted. A retake reason or "numbers wrong" is counted in `event_log` (`bp_photo_*`, code only). Code: `AiScan.kt`, `AiScreen.kt`, `MonitorScan.kt`.

Neither way judges the values. Readings feed the charts, reports and the doctor's link; lab results feed the table in the Web Dashboard.

Architecture and technology

The components, how they talk, where the data live and how a new version is released.



Components

Part	Technology	Folder
Android app	Kotlin, Compose, minSdk 26, target 34	android/
Server	Cloudflare Workers, TypeScript	worker/src/
Database	Cloudflare D1 (SQLite), EU jurisdiction	worker/schema.sql
Web dashboard	HTML/JS, own SVG charts, jsPDF + svg2pdf	worker/public/my/
Sign-in	Sign in with Google (OAuth 2.0 / OpenID Connect) + phone key	Google.kt
Subscription	Google Play Billing + Play Developer API	Billing.kt , billing.ts
Build, release	GitHub Actions, Gradle, Wrangler	.github/workflows/
Guides, documents	HTML → PDF (Playwright)	docs/

Database tables

persons · accounts (pseudonymous account code, Google fingerprint, no email; subscription sub_*) · measurements pressure + lab results · lab_files keyed file fingerprints (no duplicates) · scans · ledger · person_keys left from the removed AI Scan, emptied every night · acceptances accepted terms (versioned evidence) · web_* web access and doctor links · settings · invites · error_log · event_log (import outcomes, codes only) · seen_sigs · rate_limits protection counters; security_snapshot_findings completed scan snapshots.

Security and data

- Phone:** a private key that never leaves the phone signs every request; bad signatures, clocks off by over 5 min and replayed canonical messages are refused; mandatory Google nonce, single-use token and browser revocation on recovery.
- Limits:** hourly/daily caps on sign-ups, sign-ins, links, logs, voice (rate_limits , IP only as SHA-256). CSP and anti-framing headers; robots.txt .
- Web:** a 60 s atomically redeemed code in the # part of the address becomes the only cookie, hint_s (technical, 7 days, HttpOnly, Secure, SameSite=Strict), set only after consent. The app uses no cookies.
- Doctor links:** read-only, fixed period, expire after 7 days, withdrawable; no sign-in or cookie.
- Remote switch-off:** the app version travels with every request; settings holds app_min_version , app_blocked , app_off . Owner only, from the web Admin area.
- Owner's area** (web, owner only): four numbers only (open vulnerabilities in the app code and in the Android/iOS libraries, open defects, compliance not fully covered), the way to Observability and the version switch-off. Never values or names.
- Subscription** (ready, off until Google Play): Play Billing, checked with the Play Developer API.
- Retention:** readings older than 365 days deleted every night; acceptances in an acceptance register.
- Personal data:** no name, no email (Google account only as HMAC-SHA256); codes, cookies, links only as SHA-256; no third-party API keys; documents read on-device; only lab results and a keyed file fingerprint sync. Source files never uploaded. Cloudflare D1 is EU-bound.

Releasing a version

- Change on a branch → pull request → merge into main .
- GitHub Actions updates D1, deploys the Worker, builds the APK and the AAB, stores APK/AAB in GitHub release v0.1.N ; /download redirects there.
- The site changes at once; the app updates by installing the new APK.

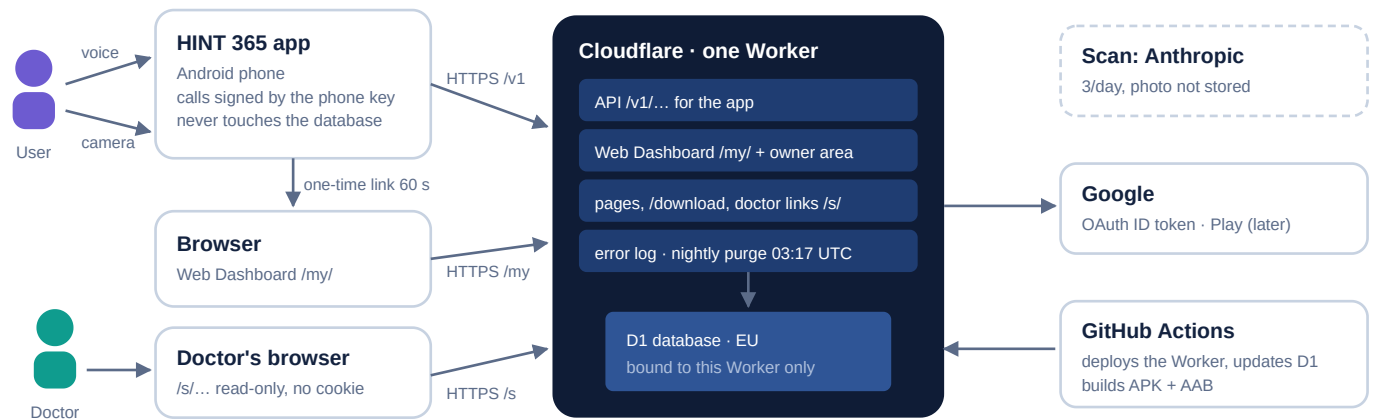
Hosting and runtime flow

Where every part runs, who talks to whom at run time, and how errors met by users are recorded.

Where it runs

Part	Runs on	Address	Operated by
Android app	The user's phone (APK; Google Play later)	installed from <code>/download</code>	the user
Web Dashboard (Blood pressure, Lab results; owner's area from the app)	Cloudflare Workers (static assets of the Worker) — not Vercel	<code>personalhealthy-api.comevava76.workers.dev/my/</code>	Cloudflare, owner's account
API for the app, public pages, doctor links	Cloudflare Workers, the same single Worker	<code>.../v1/...</code> · <code>/privacy</code> · <code>/terms</code> · <code>/s/...</code>	Cloudflare, owner's account
Database	Cloudflare D1 (SQLite), EU jurisdiction	no address: bound to the Worker only	Cloudflare, owner's account
Source, CI/CD, releases	GitHub: repository, Actions, Releases	<code>comevava76-web/personalhealthy</code> (private)	GitHub, owner's account

Runtime flow only the Worker touches the database



Error log continuous testing and improvement

- **Server:** failed signed calls (400–599, except 402, 404, 426) and every exception.
- **App:** crashes and failed PDF files; at most 20 a session.
- **Web:** script errors, at most 5 a page; never on a doctor's link.
- **Short:** one row per day, source, code, place, version, with a counter; no free-text messages, so no reading value; 90 days.

Security docs/security/

- **Each PR:** 168 security and functional checks; the app must compile.
- **Nightly:** live probe; every library (full tree) on OSV.dev; Semgrep; gitleaks → Admin → Security, with **Fix** (Claude Code).
- **Deadlines:** critical 48 h, high 7 days, moderate 30 days. Dependabot PRs on Mondays.
- **Cost:** 0 \$ extra (GitHub free plan, owner's Claude plan, OSV.dev public).

Who uses it

- **Owner:** Admin tab → total errors (90 days); the details reach the developer through the daily issue.
- **Developer:** every morning a scheduled routine reads the report of the log and fixes (page 5); in working sessions it is also read after every release.
- **Table:** `error_log` in D1, written by `worker/src/errors.ts`; app side `ErrorReport` in `Core.kt`; web side in `app.js`.

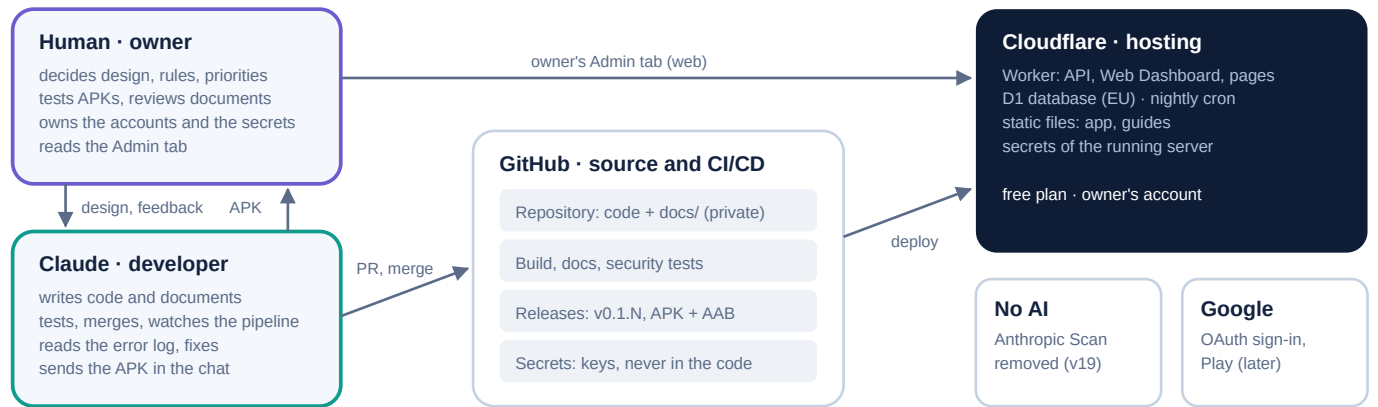
Data protection GDPR · Swiss FADP

- **Health data**, pseudonymous (not anonymous): the GDPR and the Swiss FADP apply. Basis: explicit consent (Art. 9(2)(a)) at sign-in and in the terms (v15, section "Data protection").
- **Roles:** owner = controller; Cloudflare = processor; Google and Anthropic (Scan photo, processor) in the US under their transfer safeguards; with a person's own key the photo goes to their provider under their contract (terms v21).
- **Rights:** access, correction, deletion (in the app), a copy, restriction, objection; answer within one month.
- Gaps still open and the record of processing: `docs/compliance/gdpr.md`.

Roles and delivery

Who does what — the architect, the developer, the repository and the hosting — and how a change goes from the chat to the phone.

Roles people and platforms



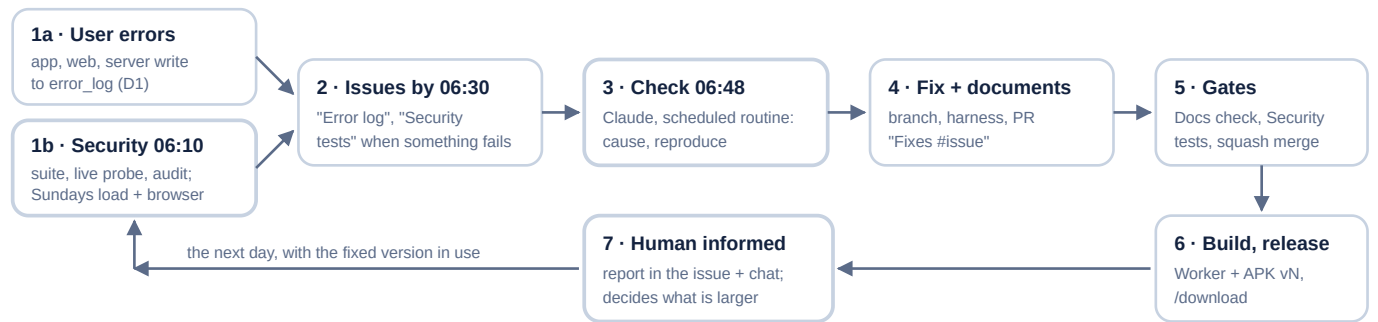
Responsibilities

Activity	Human · architect	Claude · developer	GitHub	Cloudflare
Design, rules, priorities	decides	proposes, asks when unclear	—	—
Code and documents (docs/)	reads	writes, same commit	stores	—
Tests before merge	—	runs	Docs check, Security tests	—
Merge, build, release	delegated	merges, watches	builds, releases	—
Hosting, database, cron	owns the account	—	deploys	runs
Keys and secrets	owns	never sees them	stores	stores
Trying the app on a phone	tries every APK	sends it	—	serves /download
Errors met by users	sees them in Admin	analyses, fixes	—	stores the log

Delivery, from the chat to the phone

- Decide** — Human describes the change in the chat; unclear points are asked, not guessed.
- Build and test** — Claude on `claude/...`: code and documents in one commit; harness, pages in Chromium, documents rendered.
- Merge** — pull request, *Docs check* and *Security tests* green, squash merge into `main`.
- Release** — local tests → privately signed APK/AAB → Worker + same-revision APK promotion → release record. No missing-key fallback. D1 tables, Worker, APK/AAB `v0.1.N`, `/download`; Claude checks it and sends the APK.
- Try** — Human tries the APK; feedback starts the next round. Rollback: revert the pull request.

Continuous improvement loop proactive: every day, without being asked



Security tests, vulnerability scan, Dependabot and who pays for the loop: page 4. Larger fixes wait for the human.

Application flows and permissions

Every flow of the application, step by step, and who is allowed to do what.

Application flows

#	Flow	Who	Steps	Data
1	Install, sign in	user	/download → install → Sign in with Google (OAuth, ID token checked by the Worker) → phone key registered	persons (fingerprint only)
2	Accept the terms	user	shown at first install, after every update and when the text changes → accept or the app closes	acceptances
3	Record by voice	user	Record (voice) or Scan (photo read on the phone) → check → Save → /v1/bp/voice or /photo	measurements, event_log
4	No AI	system	the Anthropic Scan was removed (terms v19): its calls answer 410 <code>ai_removed</code> ; nightly purge empties the old keys, costs and readings	person_keys, ledger, scans (emptied)
5	Screen lock	user	app lock: fingerprint, face or the phone's PIN; without any screen lock the app opens and shows a notice that leads to the settings (the user's responsibility)	none
6	See the report	user	Go to your full reports (end of Blood pressure) → Web Dashboard in a browser, Blood pressure page only: 7 days, one mean per day, the eight tiles of the app, morning/evening balance, extremes	read only
7	Share the report — app	user	Blood pressure tab, bottom → Download PDF → saved in Downloads and opened (Android 9 and older: share sheet). The file stays on the phone; the server is not involved	none on the server
8	Share the report — web	user	Go to your full reports → Web Dashboard → cookie consent → PDF download (same A4) or Send to the doctor : Email or WhatsApp only; the PDF and a read-only link (7 days) go together, with a ready message in the phone's language; withdrawable	web_sessions, web_shares
9	Doctor's view	anyone with the link	open /s/... → charts and readings of that period, PDF; nothing else	read only
10	Delete, sign out	user	Admin → delete a reading, all, or the account; Sign out ends web sessions too	deleted at once
11	Owner's Admin tab	owner	App → Admin icon (last, owner only) → web console: 4 numbers, version switch-off; Observability: vulnerabilities, EU/CH compliance, problems and fixes (import outcomes stay in the log, not on the page)	counts only
12	Import a lab report	user	Lab results → PDF or photo (own reports only, terms v18) → a progress bar: Processing → Scanning → Uploading → outcome, then it closes; the app keeps an upload history by day (saved reports from the server, uploads that saved nothing on the phone, outcome codes only); in the background, all or nothing; same file or same date and day never twice; web table: one column per date, ↑↓ orange outside the printed reference, delete a date	measurements, lab_files
13	Automatic	system	nightly: readings > 365 days, lab results never (only the user deletes them), expired links and sessions, errors > 90 days deleted; every error logged	purge, error_log

Who can do what

Action	User · app	User · web	Doctor · link	Owner	Developer
Record, delete own readings	✓	—	—	own only	—
See own charts and report, export PDF	✓	✓ (PDF)	the shared period	own only	—
Create or withdraw a doctor link	—	✓	—	own only	—
See another person's readings or report	—	—	—	never	never
See usage totals (never per account)	—	—	—	✓ Admin tab	via the owner's connector, for checks
Read the error log	—	—	—	✓ Admin tab	✓ to fix
Switch app versions off	—	—	—	✓ Admin, Actions	—
Change code, docs, deploy	—	—	—	decides	✓ through pull requests
See keys and secrets	—	—	—	✓ owns them	never

Enforced by the server: signed app calls, web session cookie, owner account, read-only expiring doctor links.